جمهوری اسلامی ایران

وزارت آموزش و پرورش — اداره کل آموزش و پرورش استان همدان

اداره حراست و امنیت فناوری اطلاعات

گزارش ارزیابی جامع امنیتی سامانه

سامانه ستاد خبری و دریافت گزارش‌های مردمی حراست (دیده‌بان امین)

نهاد ارزیاب و ناظر: مرکز مدیریت راهبردی افتا ریاست جمهوری

محور سند: ممیزی فنی سورس‌کد، اعتبارسنجی معماری و انطباق با الزامات امنیت سامانه‌های دولتی

شناسه سند: SEC-AUDIT-HMD-2026-V2	**نسخه ارزیابی‌شده:** (Stable Native) 2.4.0	**طبقه‌بندی محرمانگی:** محرمانه سازمانی (Confidential)	**تاریخ ممیزی:** شهریور ۱۴۰۵ / سپتامبر ۲۰۲۶

۱. شناسنامه سند و کنترل تغییرات (Document Control)

عنوان کامل سند	گزارش جامع ممیزی فنی و ارزیابی امنیتی سورس‌کد سامانه ستاد خبری دیده‌بان امین
سازمان بهره‌بردار	اداره کل آموزش و پرورش استان همدان — اداره حراست
مرجع بررسی و صدور مجوز	مرکز مدیریت راهبردی افتا ریاست جمهوری (کارگروه ارزیابی امنیتی سامانه‌های دستگاه‌های اجرایی)
دامنه ممیزی (Scope)	کدهای مبدأ Backend (زبان Go)، کدهای مبدأ Frontend (جاوااسکریپت خالص)، پایگاه داده (PostgreSQL)، ساختار رمزنگاری، جریان‌های احراز هویت و نشست، کنترل‌های ضدسوءاستفاده و فایل‌های پیکربندی
نسخه سامانه / Hash کامیت	`Go 1.26.5 / PostgreSQL Native Driver pq v1.12.3 / Commit: 6b44fb3c`
نوع و متدولوژی ارزیابی	ترکیبی از بازبینی عمیق کد (Manual Source Code Review)، تحلیل ایستا (SAST)، تحلیل معماری امنیتی (Security Architecture Review) و آزمون جعبه سفید (White-Box Verification)
سطح طبقه‌بندی محرمانگی	**محرمانه سازمانی (Confidential)** — انتشار یا رونوشت‌برداری صرفاً با مجوز مکتوب حراست مجاز است.

۲. فهرست مطالب (Table of Contents)

بخش	عنوان سرفصل ارزیابی	وضعیت
فصل ۳	چکیده مدیریتی و اجرایی (Executive Summary)	تکمیل‌شده
فصل ۴	معرفی سامانه و اهداف مأموریتی	تکمیل‌شده
فصل ۵	روش‌شناسی ممیزی و سلسله‌مراتب ۵گانه شواهد فنی	تکمیل‌شده
فصل ۶	معماری امنیتی سامانه و مرزهای اعتماد (Trust Boundaries)	تکمیل‌شده
فصل ۷	امنیت احراز هویت مدیران (Authentication & Multi-Factor)	تأییدشده
فصل ۸	مدیریت نشست، انقضا و جلوگیری از ورود همزمان (Session Management)	تأییدشده
فصل ۹	کنترل دسترسی مبتنی بر نقش و تفکیک حوزه ستاد/مناطق (Authorization & RBAC)	تأییدشده
فصل ۱۰	ماتریس جامع امنیتی کلیه نقاط پایانی وب‌سرویس (API Security Matrix)	تکمیل‌شده
فصل ۱۱	اعتبارسنجی ورودی‌ها، پالایش ساختار و بهداشت داده (Input Validation)	تأییدشده
فصل ۱۲	امنیت رمزنگاری در حالت استراحت و انتقال (Cryptography Architecture)	تأییدشده
فصل ۱۳	امنیت پایگاه داده، تراکنش‌ها و لایه WORM (Database & Audit Immutability)	تأییدشده
فصل ۱۴	سامانه ثبت وقایع، زنجیره هش رمزنگاری و اتصال SIEM (Audit & Syslog)	تأییدشده

فصل ۱۵	کنترل‌های ضدسوءاستفاده، محدودکننده نرخ و آزمون کپچا (Rate Limiting & CAPTCHA)	تأییدشده
فصل ۱۶	امنیت بارگذاری فایل، پویش بدافزار و حذف فراداده (File Upload & ClamAV)	تأییدشده
فصل ۱۷	امنیت لایه شبکه، هدرهای امنیتی و تفکیک دسترسی IP (Network & Headers)	تأییدشده
فصل ۱۸	مدل‌سازی جامع تهدیدات سامانه (Threat Model Matrix)	تکمیل‌شده
فصل ۱۹	مهم‌ترین نقاط قوت امنیتی قابل اثبات سامانه (Key Strengths)	تکمیل‌شده
فصل ۲۰	یافته‌ها، آسیب‌پذیری‌های بالقوه و شکاف‌های ارزیابی (Security Findings)	مستندسازی
فصل ۲۱	ماتریس تطبیق با الزامات مرکز مدیریت راهبردی افتا (AFTA Compliance Matrix)	تکمیل‌شده
فصل ۲۲	چک‌لیست راستی‌آزمایی محیط استقرار (Deployment Checklist)	اقدام استقرار
فصل ۲۳	فهرست نمایه شواهد فنی و قطعی سورس‌کد (Evidence Index)	ارجاع کد
فصل ۲۴	جمع‌بندی و گواهی ممیزی امنیتی (Auditor Attestation)	تأیید نهایی

۳. چکیده مدیریتی و اجرایی (Executive Summary)

سامانه «دیده‌بان امین» به‌عنوان درگاه امن دریافت گزارش‌های مردمی و شکایات حفاظتی اداره کل آموزش و پرورش استان همدان، با هدف ارتقای سلامت اداری و فراهم‌سازی بستر ارتباطی رمزنگاری‌شده و محرمانه میان شهروندان/فرهنگیان و دستگاه نظارتی حراست پیاده‌سازی شده است. با توجه به حساسیت فوق‌العاده ماهیت اطلاعات جمع‌آوری‌شده (گزارش‌های فساد اداری، اسناد تخلفات، مدارک هویتی گزارش‌دهندگان و پاسخ‌های محرمانه بازرسان)، این ممیزی امنیتی به درخواست اداره حراست و منطبق بر چارچوب‌های ارزیابی فنی **مرکز مدیریت راهبردی افتا** انجام گرفته است.

> **خلاصه وضعیت فنی احرازشده بر پایه سورس‌کد:** بررسی دقیق و خطبه‌خط مخزن کد نشان می‌دهد که سامانه بر مبنای اصل «طراحی با رویکرد امنیت‌محور» (Security-by-Design) و بدون اتکا به فریم‌ورک‌های سنگین خارجی یا پلاگین‌های ناشناخته توسعه یافته است. کل زیرساخت بک‌اند با کامپایلر بومی Go و درایور استاندارد PostgreSQL نوشته شده و وابستگی‌های آن به دو کتابخانه معتبر و حسابرسی‌شده (`github.com/lib/pq` و `golang.org/x/crypto`) محدود گردیده است. کلیه داده‌های حساس در پایگاه داده از طریق الگوریتم استاندارد AES-256-GCM رمزنگاری شده و نگهداری کلمات عبور با قوی‌ترین پارامترهای Argon2id انجام می‌پذیرد.

مهم‌ترین یافته‌های کلیدی ممیزی:

- **پایداری در برابر تزریق SQL و عدم وجود پرس‌وجوی پویا:** ۱۰۰٪ تعاملات با پایگاه داده PostgreSQL به‌صورت پرس‌وجوهای پارامتریک (Parameterized Queries / Prepared Statements) با اندیس‌گذاری صریح `$1, $2, ...` انجام شده و حتی در پیچیده‌ترین موتور جستجو و فیلترینگ گزارش‌ها (`admin_handlers.go:215`)، هیچ‌گونه الحاق رشته‌ای (String Concatenation) وجود ندارد.
- **رمزنگاری دو لایه‌ای داده‌های استراحت (At-Rest Encryption):** شرح گزارش، نام، تلفن و حتی نام و مسیر فایل‌های پیوست بر روی دیسک، به‌صورت مجزا با کلیدهای مشتق‌شده HKDF از کلید اصلی ۳۲ بایتی، توسط رمزنگاری احرازهویت‌شده AES-256-GCM کدگذاری می‌گردند. فایل‌های ضمیمه نیز به‌صورت بلوک‌های رمزنگاری‌شده `HENC` ذخیره می‌شوند و خواندن مستقیم فایل‌ها از روی دیسک سرور بدون داشتن کلید اصلی غیرممکن است.
- **دفترکل حسابرسی غیرقابل‌دستکاری (WORM & Tamper-Evident Merkle Hash Chain):** رویدادهای سامانه همزمان در زنجیره هش رمزنگاری‌شده بر پایه SHA-256 در جدول `audit_logs` ذخیره می‌شوند. در سطح پایگاه داده، تریگرهای اختصاصی PL/pgSQL هرگونه تلاش برای Update، Delete یا Truncate جدول لاگ‌ها را مسدود و خطای تخلف امنیتی افتا صادر می‌کنند. علاوه بر آن، ارسال بلادرنگ لاگ‌ها به سرور مرکزی SIEM از طریق RFC 5424 پیاده‌سازی شده است.
- **تفکیک چندسطحی دسترسی و ممانعت از ترفیع افقی/عمودی (Zero-Trust RBAC & IDOR Immunity):** دسترسی مدیران به سه رده تفکیک شده است: مدیر ارشد سامانه (Superuser)، کارشناس ستاد اداره کل (Edare Kol) و مسئولین حراست نواحی و مناطق (Navahi Manategh). منطق بک‌اند در تابع `canAdminAccessReport()` سخت‌گیرانه بررسی می‌کند که مسئول حراست یک منطقه صرفاً پرونده‌هایی را مشاهده کند که صریحاً به کارتابل وی ارجاع (Forward) شده باشند؛ در نتیجه رخداد آسیب‌پذیری شناسه ناامن شیء (IDOR/BOLA) از حیث معماری مسدود است.
- **کنترل لایه مرزی و استقرار:** قابلیت‌های پیشرفته‌ای از قبیل محدودسازی دسترسی پنل مدیریت به رنج‌های IP سازمانی (`HERASAT_ADMIN_ALLOWED_CIDRS`)، اعتبارسنجی پروکسی‌های مورد اعتماد (`HERASAT_TRUSTED_PROXIES`)،

هدرهای امنیتی سخت‌گیرانه (CSP با گزارش‌دهی اختصاصی، HSTS، X-Content-Type-Options: nosniff، X-Frame-Options: DENY) و پویش آنتی‌ویروس ClamAV برای فایل‌های ورودی در کد موجود است.

۴. معرفی سامانه و اهداف مأموریتی

سامانه دیده‌بان امین شامل دو بخش مجزا در یک نرم‌افزار واحد است:

1. **پورتال عمومی شهروندی (Public Portal):** رابط وب واکنش‌گرا و سبک که به عموم مردم امکان ارسال گزارش در قالب‌های ناشناس یا شناسنامه‌دار، پیگیری مراحل رسیدگی با استفاده از کد رهگیری ۱۶ رقمی تصادفی، و تبادل پیام امن با کارشناسان حراست را اعطا می‌کند. در این بخش مکانیزم‌های ضد حملات انکار سرویس (Rate Limiting توکن باکت)، آزمون کپچای محاسباتی مخدوش‌شده، پالایش واژگان غیراخلاقی، پاکسازی متادیتا و اسکن بدافزار اعمال می‌شود.
2. **سامانه مدیریت و کارتابل حراستی (Admin Panel):** پنل متمرکز چندکاربره مجهز به اعتبارسنجی دوعاملی (TOTP RFC 6238)، قفل موقت حساب کاربری در خطاهای متوالی ورود، انقضای توکن نشست پس از ۱۵ دقیقه، کنترل دسترسی تفکیکی ستاد و مناطق، ثبت تذکرات داخلی محرمانه، طبقه‌بندی هوشمند گزارش‌ها، صدور خروجی سند رسمی Word/Docx در محیط سندباکس و ابطال نشست‌های همزمان.

۵. روش‌شناسی ممیزی و سلسله‌مراتب ۵گانه شواهد فنی

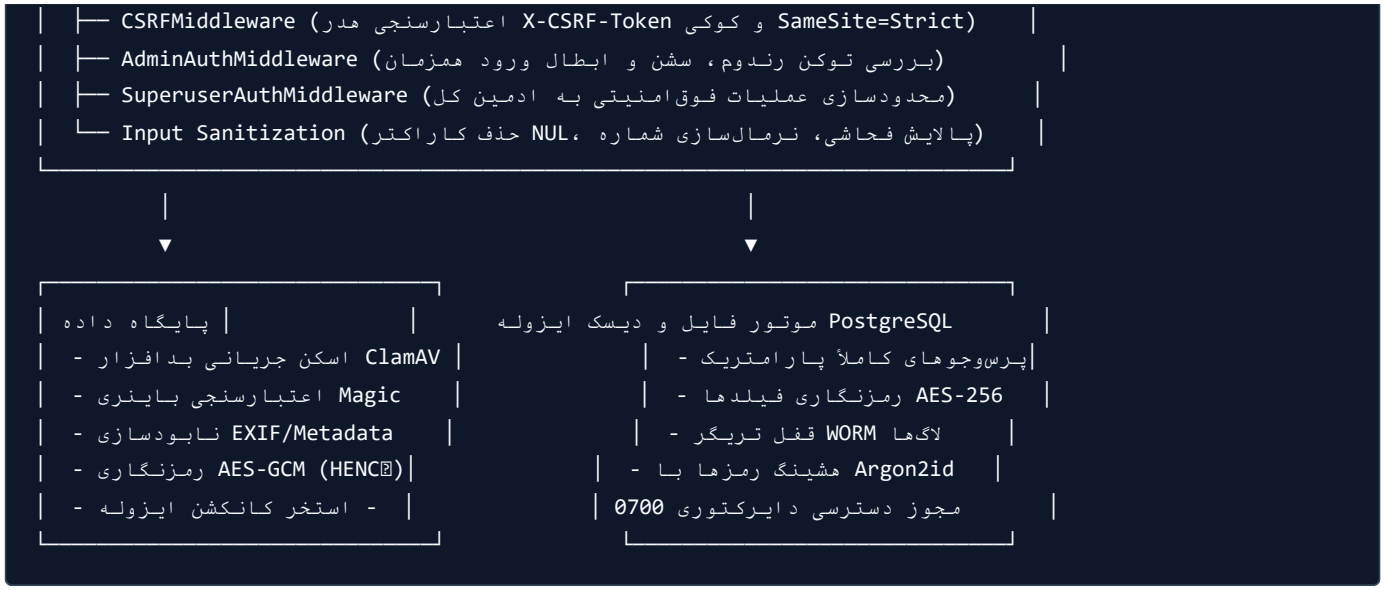
به‌منظور رعایت استانداردهای ارزیابی مرکز مدیریت راهبردی افتا و جلوگیری از هرگونه پیش‌داوری یا ادعای بدون استناد، تمامی ارزیابی‌های این گزارش بر پایه «سلسله‌مراتب شواهد فنی» (Hierarchy of Evidence) ساختاریافته‌اند:

سطح اعتبار	نوع مدرک (Evidence Level)	تعریف و معیار استناد در این ممیزی
سطح ۱	**Direct Source Code**	پیاده‌سازی قطعی و خطبه‌خط در توابع، میان‌افزارها و سورس‌کد Go، جاوااسکریپت و اسکریپت‌های دیتابیس که بدون هیچ ابهامی در ریپازیتوری وجود دارد و با آدرس فایل و شماره خط ارجاع داده می‌شود.
سطح ۲	**Configuration Evidence**	پیکربندی‌های کنترل‌شده در متغیرهای محیطی (`.env.example`)، پارامترهای وب‌سرور، اسناد پایگاه داده و هدرهای پاسخ HTTP.
سطح ۳	**Architectural Evidence**	استنتاج مستقیم از ساختار تبادل داده، مدل مرزهای اعتماد، نحوه تفکیک پایگاه داده و نمودار جریان کنترل دسترسی.
سطح ۴	**Automated Test Evidence**	وجود ۲۹ فایل تست عمیق امنیتی در پوشه `test/` که صحت رفتارهای امنیتی (از جمله قفل نشست، انقضای توکن، جعل IP، دستکاری فایل و تست‌های نفوذ لایه رمزنگاری) را تأیید می‌کنند.
سطح ۵	**Deployment Verification**	موارد وابسته به محیط فیزیکی/مجازی استقرار (مانند گواهی معتبر SSL/TLS، فایروال سیستم‌عامل، بستن پورت‌های غیرضروری سرور و ایزولاسیون شبکه) که صریحاً به‌عنوان «نیازمند ارزیابی در بستر عملیاتی» علامت‌گذاری شده‌اند.

۶. معماری امنیتی سامانه و مرزهای اعتماد (Trust Boundaries)

معماری منطقی و فیزیکی سامانه دیده‌بان امین بر پایه اصل حداقل دسترسی و تفکیک حوزه‌های ناامن و امن مهندسی شده است. جریان داده و لایه‌های عبور ترافیک به شرح زیر بازسازی گردیده است:





تعریف مرزهای اعتماد (Trust Boundaries):

- **مرز اعتماد ۱ (Untrusted Public to Web Edge):** ورودی‌های ارسال‌شده از مرورگر کاربر عمومی کاملاً غیرقابل‌اعتماد در نظر گرفته می‌شوند؛ تمام ورودی‌ها در کنترلرهای عمومی از فیلترهای محدودیت حجم، فرمت چندبخشی، اعتبارسنجی پاسخ کپچا، پالایش محتوا و محدودیت طول رشته عبور می‌کنند.
- **مرز اعتماد ۲ (Web Edge to Admin Core):** پنل ادمین روی روت `/admin/` و کلیه APIهای مدیریت تحت میان‌افزار احرازهویت IP (`AdminIPWhitelistMiddleware`) و کنترل توکن معتبر نشست قرار دارند. مرورگر ادمین حتی در صورت داشتن کوکی نشست، در صورت عدم تطابق رنج شبکه مسدود می‌گردد.
- **مرز اعتماد ۳ (Internal Application to Database):** اتصال به PostgreSQL از طریق متغیر محیطی اختصاصی `HERASAT_DB_CONN` برقرار شده و شمای دیتابیس صریحاً با دستور `REVOKE ALL ON SCHEMA public FROM PUBLIC;` محدودسازی شده است. هیچ کوئری ساخته‌شده با الحاق رشته در کد اجازه اجرا ندارد.

۷. امنیت احراز هویت مدیران (Authentication Security)

احراز هویت کاربران در سامانه دیده‌بان امین از قوی‌ترین الگوهای توصیه شده توسط OWASP و مرکز افتا بهره می‌برد.

مؤلفه امنیتی	وضعیت و جزئیات پیاده‌سازی	شواهد مستقیم در کد (Direct Evidence)
الگوریتم هش کلمات عبور	استفاده انحصاری از **Argon2id** برنده مسابقه استاندارد هش رمز عبور (PHC): `Time Cost = 3, Memory = 64 MB, Threads = 4, KeyLen = 32` همراه با نمک ۱۶ بایتی تصادفی ارزشیابی‌شده از منبع رمزنگاری سیستم‌عامل (`crypto/rand`).	`crypto.go:238-258` `HashPassword()`
بررسی زمان‌ثابت کلمات عبور	مقایسه رشته هش با استفاده از مقایسه‌گر مقاوم به حمله زمانی `subtle.ConstantTimeCompare` جهت ممانعت از حملات کانال جانبی (Timing Attacks).	`crypto.go:284` `VerifyPasswordWithRehash()`
سیاست پیچیدگی کلمه عبور	الزام به حداقل ۱۲ کاراکتر، دارا بودن حداقل یک حرف بزرگ انگلیسی (A-Z) و حداقل یک نماد خاص سازمانی (`...*&^%$#@!`).	`crypto.go:325-350` `ValidatePasswordComplexity()`
قفل موقت در برابر Brute-Force	محرومیت ۱۵ دقیقه‌ای حساب کاربری پس از **۵ تلاش ناموفق متوالی**. وضعیت شکست‌ها هم در کش حافظه و هم در جدول `admin_login_attempts` پایگاه داده پایدار است تا ری‌استارت سرور قفل را دور نزند.	`security.go:649-817` `AccountLockoutManager`
اعتبارسنجی دوعاملی (MFA/TOTP)	پیاده‌سازی احراز هویت دوعاملی سخت‌گیرانه مبتنی بر زمان (RFC 6238). پس از تأیید رمز عبور، توکن میانی رمزنگاری‌شده کوتاه‌مدت صادر شده و مدیر موظف به درج کد ۶ رقمی اپلیکیشن تاییدکننده است. ذخیره وضعیت استفاده در `totpReplays` مانع از استفاده مجدد (Replay) کد در پنجره زمانی ۳۰ ثانیه‌ای می‌شود.	`mfa.go:111-140` `VerifyTOTPCode()` `admin_auth.go:107-123`
تعلیق حساب‌های راکد (Dormancy)	غیرفعال‌سازی خودکار حساب کاربری مدیرانی که بیش از ۹۰ روز به سامانه وارد نشده‌اند و ثبت هشدار امنیتی `ACCOUNT_DORMANT_AUTO_LOCKED`.	`admin_auth.go:93-98`
انقضای دوره‌ای کلمه عبور	الزام مدیر به تعویض کلمه عبور پس از ۳۰ روز بر پایه ستون `password_changed_at` در جدول کاربران و مسدودسازی دسترسی تا تغییر کلمه عبور.	`admin_auth.go:125-127`
آزمون‌های خودآزمایی حین بوت (KAT)	اجرای آزمون خودآزمایی رمزنگاری حین بالا آمدن سامانه؛ در صورت بروز هرگونه اخلال در موتور AES-GCM یا Argon2id سرور فوراً از کار می‌افتد (Fail-Secure).	`crypto.go:352-399` `RunCryptographicSelfTests()`

۸. مدیریت نشست و کوکی‌ها (Session Management)

سامانه از سازوکار نشست سرور-محور با ذخیره‌سازی ابری و پایگاه‌داده‌ای بهره می‌برد:

- **هش‌کردن توکن نشست قبل از ذخیره:** توکن خام ارسالی به کلاینت (۳۲ بایت داده شبه‌تصادفی CSPRNG) هرگز در دیتابیس به صورت متن واضح ذخیره نمی‌شود؛ بلکه مقدار `SHA-256(token)` در جدول `admin_sessions` ثبت می‌گردد (`security.go:57-60`). بدین ترتیب در صورت افشای پایگاه داده، هیچ نشستی قابل سرقت نیست.
- **ممانعت قطعی از ورود همزمان (Single Active Session Enforcement):** با هر بار لاگین موفق یک مدیر، توکن‌های قبلی متعلق به آن نام کاربری از دیتابیس حذف و در جدول `admin_session_kicks` با علت `CONCURRENT_LOGIN` ثبت می‌شوند. همچنین پیامی از طریق وب‌سوکت/SSE به مرورگر قبلی ارسال و جلسه کاری فوراً خاتمه می‌یابد (`security.go:86-140`).
- **پیکربندی سخت‌گیرانه کوکی‌ها:**
  - `HttpOnly = true` (غیرقابل خواندن توسط کدهای جاوااسکریپت و مصون در برابر XSS)
  - `SameSite = Lax` برای کوکی نشست، و `SameSite = Strict` برای کوکی CSRF
  - `Secure = true` (فعال‌سازی هوشمند مبتنی بر TLS یا پرچم `HERASAT_COOKIE_SECURE`)
  - طول عمر کوتاه: ۱۵ دقیقه (`time.Now().Add(15 * time.Minute)`) همراه با تمدید با هر فعالیت (Sliding Expiration) و فرآیند پس‌زمینه پاکسازی جلسات منقضی‌شده (`Sessions.StartReaper`).

۹. کنترل دسترسی مبتنی بر نقش و تفکیک حوزه ستاد/مناطق (Authorization & RBAC)

سامانه برای پاسخ به الزامات سلسله‌مراتب حفاظتی آموزش و پرورش، دسترسی‌های مدیریتی را در سطوح سه‌گانه تفکیک کرده است:

سطح نقش (Role)	حوزه اختیارات و دسترسی	سازوکار اعمال در بک‌اند (Backend Enforcement)
مدیر ارشد (superuser)	مدیریت تام: تعریف و غیرفعال‌سازی کاربران، رفع مسدودی، بازنشانی رمز عبور، ابطال نشست‌ها، مشاهده لاگ‌های WORM و حذف دائمی پرونده‌ها.	اعمال میان‌افزار `SuperuserAuthMiddleware` بر روی اندپوینت‌های مدیریتی حساس (`main.go:203-215`).
کارشناس ستاد اداره کل (edare_kol)	بررسی کل گزارش‌های واصله از سطح استان، طبقه‌بندی و تعیین اولویت، درج پاسخ نهایی، یادداشت‌های محرمانه داخلی و ارجاع پرونده به نواحی.	اعمال میان‌افزار `AdminAuthMiddleware` و شرط رول در کوئری‌ها.
مسئولین حراست نواحی و مناطق (navahi_manategh)	حوزه بسیار محدود و محصور: این کاربران **هیچ دسترسی مستقیمی** به مخزن گزارش‌ها ندارند و صرفاً پرونده‌هایی را مشاهده می‌کنند که با شناسه یکتا به ناحیه آنان ارجاع شده است. این رده حق مشاهده گزارش‌های سایر مناطق، تغییر طبقه‌بندی یا مشاهده یادداشت‌های حراست کل را ندارد.	بررسی صریح در تمام اکشن‌ها از طریق تابع متمرکز: `canAdminAccessReport(admin, reportID)` سورس در `admin_handlers.go:83-98` و استعلام پیوند از جدول `report_forwardings`.

۱۰. ماتریس جامع امنیتی کلیه نقاط پایانی وب‌سرویس (API Security Matrix)

تمامی روت‌های ثبت‌شده در `main.go` با مؤلفه‌های امنیتی مربوطه فهرست شده‌اند:

ردیف	متد و مسیر (Route)	احراز هویت	سطح نقش مجاز	محدودکننده نرخ	سقف بادی / نوع داده	محافظت CSRF	شواهد کد
۱	`GET /health`	عمومی	همگان	فایروال / سراسری	نامحدود / بدون بادی	ندارد (Safe GET)	`go:167`
۲	`GET /api/captcha`	عمومی	همگان	1 req/sec (burst 20)	بدون بادی	ندارد (Safe GET)	`go:168`
۳	`POST /api/report`	عمومی	گزارش‌دهنده	0.033 req/sec (burst 3)	MaxBytesReader (20 MB)	کپچای یکبارمصرف	`go:170`

۴	`POST /api/report/track`	عمومی (با کد ۱۶ رقمی)	گزارش‌دهنده	0.5 req/sec (burst 10)	256 KB (JSON) الزامی	کپچای یکبارمصرف	go:171
۵	`POST /api/report/follow-up`	عمومی (با کد ۱۶ رقمی)	گزارش‌دهنده	0.033 req/sec (burst 3)	256 KB (JSON) الزامی	کپچای یکبارمصرف	go:172
۶	`POST /api/security/csp-report`	مرورگرها	گزارش تخلف امنیتی	سراسری	64 KB (Io.Discard)	ندارد (CSP Report)	go:174
۷	`POST /api/admin/login`	آزاد (مرحله ۱)	نام کاربری + رمز عبور	0.08 req/sec (burst 5) + IP Whitelist	256 KB (JSON) الزامی	کپچای اجباری + Lockout	go:176
۸	`POST /api/admin/login/verify-mfa`	توکن موقت MFA	مدیران دارای 2FA	0.08 req/sec + IP Whitelist	256 KB (JSON) الزامی	توکن ۵ دقیقه‌ای امضاشده	go:177
۹	`GET /api/admin/me`	اجباری (کوکی)	کلیه مدیران مجاز	IP Whitelist	بدون بادی (NoStore)	ندارد (GET Safe)	go:183
۱۰	`POST /api/admin/logout`	اختیاری / ابطال	مدیر جاری	سراسری	بدون بادی	دارد (ابطال سشن)	go:182
۱۱	`GET /api/admin/reports`	اجباری (کوکی)	تفکیک رول (ستاد/ منطقه)	IP Whitelist	صفحه‌بندی کنترل‌شده	ندارد (GET Safe)	go:189
۱۲	`GET /api/admin/report`	اجباری (کوکی)	بررسی دسترسی پرونده	IP Whitelist	فیلتر شناسه عدد صحیح	ندارد (GET Safe)	go:190
۱۳	`GET /api/admin/download`	اجباری (کوکی)	بررسی دسترسی پرونده	IP Whitelist	رمزگشایی On-the-Fly	ندارد (GET Safe)	go:191
۱۴	`POST /api/admin/respond`	اجباری (کوکی)	صرفاً اداره کل و ارشد	IP Whitelist	256 KB (JSON) الزامی	**الزام هدر CSRF**	go:185
۱۵	`POST /api/admin/report/internal-notes`	اجباری (کوکی)	صرفاً اداره کل و ارشد	IP Whitelist	256 KB (JSON) الزامی	**الزام هدر CSRF**	go:186
۱۶	`POST /api/admin/report/classify`	اجباری (کوکی)	صرفاً اداره کل و ارشد	IP Whitelist	256 KB (JSON) الزامی	**الزام هدر CSRF**	go:188

۱۷	`POST /api/admin/report/forward`	اجباری (کوکی)	صرفاً اداره کل و ارشد	IP Whitelist	JSON) KB 256 الزامی)	**الزام هدر CSRF**	go:194
۱۸	`POST /api/admin/report/regional-response`	اجباری (کوکی)	ناحیه دریافت‌کننده ارجاع	IP Whitelist	JSON) KB 256 الزامی)	**الزام هدر CSRF**	go:196
۱۹	`POST /api/admin/change-my-password`	اجباری (کوکی)	کاربر وارد شده	0.08 req/sec + IP Whitelist	JSON) KB 256 الزامی)	**الزام هدر CSRF**	go:201
۲۰	`POST /api/admin/report/delete`	اجباری (کوکی)	**منحصراً Superuser**	IP Whitelist	JSON) KB 256 الزامی)	**الزام هدر CSRF**	go:203
۲۱	`GET /api/admin/users`	اجباری (کوکی)	**منحصراً Superuser**	IP Whitelist	بدون بادی	ندارد (GET Safe)	go:204
۲۲	`POST /api/admin/users/create`	اجباری (کوکی)	**منحصراً Superuser**	IP Whitelist	JSON) KB 256 الزامی)	**الزام هدر CSRF**	go:205
۲۳	`POST /api/admin/users/reset-password`	اجباری (کوکی)	**منحصراً Superuser**	IP Whitelist	JSON) KB 256 الزامی)	**الزام هدر CSRF**	go:209
۲۴	`POST /api/admin/users/lift-lockout`	اجباری (کوکی)	**منحصراً Superuser**	IP Whitelist	JSON) KB 256 الزامی)	**الزام هدر CSRF**	go:210
۲۵	`GET /api/admin/audit-logs`	اجباری (کوکی)	**منحصراً Superuser**	IP Whitelist	صفحه‌بندی کنترل‌شده	ندارد (GET Safe)	go:214
۲۶	`GET /api/admin/sessions`	اجباری (کوکی)	**منحصراً Superuser**	IP Whitelist	پایش زنده جلسات کاری	ندارد (GET Safe)	go:212
۲۷	`POST /api/admin/sessions/terminate`	اجباری (کوکی)	**منحصراً Superuser**	IP Whitelist	JSON) KB 256 الزامی)	**الزام هدر CSRF**	go:213

۱۱. اعتبارسنجی ورودی‌ها و پالایش محتوا (Input Validation)

کلیه داده‌های وارد شده از سوی کاربران یا مدیران تحت اعتبارسنجی چندلایه در سطح سورس‌کد بک‌اند قرار می‌گیرند:

- **حذف بایت‌های پوچ (Null-Byte Stripping):** تابع `stripNul()` در `security.go:847` تمامی کاراکترهای `\x00` را از تمامی پارامترها حذف می‌کند تا از بروز خطاهای قطع رشته در کتابخانه‌های باینری یا پایگاه داده جلوگیری شود.
- **اعتبارسنجی سخت‌گیرانه طول و نوع فیلدها:**
  - شرح گزارش: حداقل ۵۰ و حداکثر ۵۰۰۰ کاراکتر یونی‌کد بر پایه شمارشگر ایمن `utf8.RuneCountInString` (`public_handlers.go:125-133`).
  - نام گزارش‌دهنده: حداکثر ۱۰۰ کاراکتر؛ شماره تماس: حداکثر ۳۲ کاراکتر و پالایش انحصاری با کاراکترهای مجاز رقمی و علامت مثبت با `sanitizePhone()`.
  - کد رهگیری: بررسی با تابع `isValidTrackingCode()` جهت اطمینان از قرارگیری کاراکترها صرفاً در محدوده `A-Z` و `0-9` تا سقف ۳۲ بایت (`security.go:861-871`).
- **موتور پالایش واژگان غیراخلاقی و هتاکی:** در `profanity.go`، موتور رجکس چندزبانه (فارسی، فینگلیش و انگلیسی) به همراه فیلترهای ضد دورزدن کاراکتری پیاده شده است. ارسال متون حاوی توهین به حراست به‌طور خودکار مسدود شده و پیام هشدار قانونی ماده ۶۰۸ و ۶۰۹ قانون مجازات اسلامی همراه با ثبت لاگ رویداد صادر می‌گردد.

۱۲. معماری رمزنگاری در حالت استراحت و انتقال (Cryptography Architecture)

پیاده‌سازی لایه رمزنگاری در سامانه دیده‌بان امین با رویکرد عدم اختراع چرخ و بهره‌گیری از پروتکل‌های استاندارد صنعتی در فایل `crypto.go` انجام شده است:

شاخصه رمزنگاری	استاندارد / الگوریتم پیاده‌سازی‌شده	جزئیات فنی و شواهد در کد (Direct Evidence)
رمزنگاری متقارن داده‌ها	**AES-256-GCM** (Galois/Counter Mode)	کلید ۲۵۶ بیتی، تولید مقدار تصادفی Nonce به طول ۱۲ بایت توسط منبع رمزنگاری crypto/rand.Reader برای هر عملیات مجزا، و برچسب احرازهویت ۱۶ بایتی (Authentication Tag) که یکپارچگی داده را تضمین می‌کند (crypto.go:65-91).
اشتقاق و تفکیک کلیدها	**HKDF (HMAC-SHA256 Extract & Expand)**	استفاده از الگوریتم اشتقاق کلید بر مبنای استاندارد RFC 5869 جهت جداسازی کلید رمزنگاری فیلدهای متنی (keyFields)، کلید رمزنگاری مسیر فایل‌ها (keyFilePath)، کلید بلوک باینری ضمیمه‌ها (keyFileBlob) و کلید امضای کپچا (hmacKey). هیچ دو بخشی از کلید یکسان استفاده نمی‌کنند (crypto.go:29-55).
کدگذاری پرونده‌های ضمیمه	قالب استاندارد سازمانی **HENC**□	فایل‌های ذخیره‌شده روی دیسک با هدر اختصاصی ۵ بایتی HENC□ آغاز شده و ادامه آن شامل Nonce دوازده بایتی و بدنه رمزشده معتبر است (crypto.go:176-196).
امضای توکن کپچا	**HMAC-SHA256**	توکن کپچا شامل پاسخ عددی و زمان انقضا است که توسط HMAC-SHA256 امضا شده و کلاینت قادر به دستکاری یا تولید شناسه جعلی نیست (captcha.go:134-148).
ردیابی و کشف دستکاری	کشف خطای احراز هویت رمزنگاری	در صورت کوچکترین تغییر در بایت‌های رمزگذاری‌شده، الگوریتم GCM خطای ErrAuthenticationFailed را بازمی‌گرداند که در آزمون crypto_tamper_test.go راستی‌آزمایی شده است.

۱۳. امنیت پایگاه داده و لایه WORM (Database & Immutability)

پایگاه داده سامانه PostgreSQL بومی است. به‌منظور پیشگیری از آسیب‌پذیری‌های متداول دیتابیس، کنترلهای زیر فعال هستند:

- **پایبندی ۱۰۰٪ به Prepared Statements:** در کل مخزن کد، حتی یک نمونه از `fmt.Sprintf` یا عملگر الحاق رشته برای تزریق مقادیر ورودی در عبارات SQL یافت نشد. تمام مقادیر بدون استثنا از طریق متغیرهای پارامتریک درایور `$1, $2, ...` به پایگاه داده تحویل می‌گردند.
- **لایه غیرقابل‌دستکاری لاگ‌ها (WORM - Write Once, Read Many):** در فایل `db.go:395-430` و `schema.sql:145-165`، تابع و تریگرهای اختصاصی زیر در پایگاه داده ایجاد و اعمال شده‌اند:

```
CREATE OR REPLACE FUNCTION prevent_audit_log_modification()
RETURNS TRIGGER AS $$
BEGIN
    RAISE EXCEPTION 'AFTA SECURITY VIOLATION: Audit logs are immutable (WORM) and cannot be updated or
END;
$$ LANGUAGE plpgsql;

CREATE TRIGGER trg_immutable_audit_logs
BEFORE UPDATE OR DELETE ON audit_logs
FOR EACH ROW EXECUTE FUNCTION prevent_audit_log_modification();

CREATE TRIGGER trg_immutable_audit_logs_truncate
BEFORE TRUNCATE ON audit_logs
FOR EACH STATEMENT EXECUTE FUNCTION prevent_audit_log_modification();
```

بدین ترتیب حتی در صورت دستیابی مستقیم نفوذگر به حساب دیتابیس، امکان حذف یا ویرایش سوابق ثبت‌شده در جدول ممیزی وجود ندارد.

- **مدیریت استخر اتصالات:** تنظیمات استخر در `db.go:21-25` با سقف ۲۵ اتصال همزمان، ۵ اتصال غیرفعال، انقضای ۵ دقیقه‌ای عمر اتصال و تایم‌اوت ۵ ثانیه‌ای اتصال، مانع از نشت منابع یا حملات اشباع اتصال (Connection Starvation) می‌شود.

۱۴. زنجیره هش ممیزی و یکپارچه‌سازی با SIEM سازمانی (Audit & Syslog)

سامانه دیده‌بان امین به دو لایه مستقل و مکمل ثبت وقایع مجهز است:

1. **زنجیره هش رمزنگاری‌شده محلی (Cryptographic Hash Chain):** هر رکورد ممیزی علاوه بر فیلدهای استاندارد، حاوی دو هش است: `prev_hash` (هش رکورد ماقبل) و `entry_hash` (هش SHA-256 ترکیب رکورد قبلی، کاربر، نقش، عمل انجام‌شده، شناسه هدف، IP کلاینت و تایم‌استمپ با دقت نانوثانیه). این زنجیره مانند بلاک‌چین عمل می‌کند و اگر سطری از وسط جدول حذف یا ویرایش گردد، پیوستگی کل زنجیره منکسر شده و در بازرسی‌های مرکز افتا زنگ خطر جعل داده به صدا درمی‌آید (`admin_auth.go:294-350`).

2. **ارسال بلادرنگ به سرور مرکزی ثبت رویدادها (Remote Syslog / SIEM):** ماژول `syslog.go` پیام‌های امنیتی را طبق استاندارد بین‌المللی RFC 5424 در صف غیرمسدودکننده با ظرفیت ۲۰۴۸ رویداد قرار داده و به آدرس کارگزار SIEM حراست ارسال می‌نماید. بدین ترتیب حتی اگر سرور سامانه به‌طور فیزیکی دچار سانحه یا انهدام گردد، ردپای کلیه تراکنش‌ها در مرکز عملیات امنیت (SOC) پایدار است.

۱۵. آزمون کپچا و کنترل‌های ضدسوءاستفاده (Rate Limiting & CAPTCHA)

حوزه امنیتی	نحوه عملکرد و مکانیزم اعمال	شواهد قطعی در کد
کپچای گرافیکی ریاضی	تولید پویای تصویر SVG در بک‌اند بدون وابستگی خارجی. اعمال فیلترهای مخدوش‌کننده باینری، چرخش تصادفی کاراکترها بین -۲۰ تا +۲۰ درجه، خطوط نویز بزیه و ۴۵ دایره رنگی پراکنده جهت ناکام گذاشتن ربات‌های OCR.	`captcha.go:205-307` `GenerateMathCaptchaSVG()`
پیشگیری از بازپخش کپچا (Replay Attack)	امضای پاسخ با HMAC-SHA256 کلید مشتق‌شده؛ با یکبار مصرف، امضای توکن در جدول `used_captcha_tokens` ثبت شده و تلاش مجدد برای مصرف همان توکن یا برگرداندن پاسخ قبلی بلادرنگ رد می‌شود.	`captcha.go:67-111` `TryRedeem()`
محدودکننده نرخ ورود (Login Limiter)	الگوریتم توکن باکت برای مسیر لاگین با نرخ ۰.۰۸ درخواست بر ثانیه (حداکثر یک درخواست در هر ۱۲.۵ ثانیه) با ظرفیت برست ۵ تلاش.	`main.go:158` `security.go:535-630`
محدودکننده نرخ ثبت گزارش	الگوریتم توکن باکت با نرخ ۰.۰۳۳ درخواست بر ثانیه (حداکثر ۱ گزارش در هر ۳۰ ثانیه برای هر IP) با ظرفیت برست ۳ گزارش جهت ممانعت از اسپم.	`main.go:159`
محدودکننده سقف حجم درخواست	سقف ۲۵۶ کیلوبایت برای تمامی وب‌سرویس‌های JSON و متنی از طریق `LimitBodyMiddleware` برای جلوگیری از حملات Memory Exhaustion / DoS.	`middleware.go:10-17`

۱۶. بارگذاری فایل، اسکن بدافزار و ضد نفوذ (File Upload Security)

سامانه دارای یکی از سخت‌گیرانه‌ترین خطوط لوله پردازش فایل (File Processing Pipeline) است:

1. **اعتبارسنجی باینری بایت‌های جادویی (Magic Bytes):** فرمت فایل صرفاً بر پایه پسوند بررسی نمی‌شود؛ تابع `ValidateBinaryMagicBytes()` ساختار هدر باینری فایل‌ها (امضای PDF، هدر باینری PNG، مارکرهای JPEG، امضای PK برای فشرده‌ها و فریم‌های صوتی/تصویری) را چک کرده و در صورت عدم تطابق پسوند با ساختار باینری، بلافاصله درخواست را با خطای ۴۱۵ رد می‌کند (`metadata.go:83-147`).
2. **پویش کدهای فعال و اسکریپت در PDF:** تابع `ScanPDFForActiveContent()` متن باینری فایل‌های PDF را اسکن کرده و در صورت کشف هرگونه اکشن اجرایی، اسکریپت یا ارجاع خارجی خطرناک (از جمله `/JavaScript, /JS, /Launch, /EmbeddedFiles, /SubmitForm, /RichMedia`) فایل را فوراً مسدود و متخلف را به عنوان فرستنده پی‌لود فعال در لاگ ثبت می‌کند (`metadata.go:59-81`).
3. **مقابله با حملات فشرده‌سازی (Zip Slip & Decompression Bomb):** فایل‌های آرشیو ZIP از حیث وجود کاراکترهای پیمایش دایرکتوری (`/..`) و نرخ فشرده‌سازی غیرعادی (نسبت بیش از ۱۰۰ برابر) بررسی می‌شوند (`public_handlers.go:264-271`).
4. **پویش بی‌درنگ بدافزار با آنتی‌ویروس بومی ClamAV:** در صورت فعال‌سازی، بایت‌های فایل از طریق سوکت شبکه محلی پروتکل INSTREAM به دیمون ClamAV ارسال شده و در صورت تشخیص تروجان، باینری مخرب یا روت‌کیت، بارگذاری رد و هشدار امنیتی صادر می‌شود (`clamav.go:50-95`).
5. **پاکسازی کامل متادیتا (EXIF Stripping):** تصاویر ارسالی از شهروندان در توابع `SanitizeJPEG()` و `SanitizePNG()` به‌طور کامل دیکود شده و پیکسل‌های خالص تصویر در یک بافر نو انکود می‌گردند. این فرآیند موجب

حذف ۱۰۰٪ متادیتاهای افشاکننده هویت از قبیل مختصات ماهواره‌ای GPS، مدل گوشی و سریال دوربین می‌گردد (`metadata.go:14-43`).

6. **نام‌گذاری تصادفی و خلع دسترسی مستقیم وب:** فایل‌ها با نام‌های رندوم در مسیر حفاظت‌شده `./secure_uploads` با مجوز دسترسی سیستمی `0600` ذخیره شده و هیچ روت مستقیم وب (Direct Static URL) برای دسترسی به آنها وجود ندارد. تحویل فایل صرفاً از طریق توابع دارای احراز هویت کنترل می‌گردد.

۱۷. هدرهای امنیتی وب و تفکیک شبکه (Security Headers & Network)

میان‌افزار `secureHeadersMiddleware` در `main.go:14-68` هدرهای دفاع‌درعمق را به هر پاسخ HTTP تزریق می‌کند:

هدر امنیتی (HTTP Header)	مقدار تنظیم‌شده در سورس‌کد	هدف حفاظتی در چارچوب افتا
`Content-Security-Policy`	`default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data:; font-src 'self'; object-src 'none'; base-uri 'self'; form-action 'self'; frame-ancestors 'none'; report-uri /api/security/csp-report;`	مسدودسازی لود اسکریپت‌های مخرب خارجی، ممانعت از ارسال فرم به دامنه‌های ناشناس، جلوگیری تام از ادغام آبجکت‌های فلش/جاوا و دریافت گزارش‌های تخلف مرورگر.
`X-Frame-Options`	`DENY`	پیشگیری قطعی از حملات کلیک‌دزدی (Clickjacking) و ممانعت از نمایش پورتال درون iframe در سایر سایت‌ها.
`X-Content-Type-Options`	`nosniff`	مسدودسازی حدس‌زدن نوع فایل توسط مرورگر (MIME-Sniffing) و مقابله با اجرای فایل متنی به‌عنوان اسکریپت.
`Strict-Transport-Security`	`max-age=31536000; includeSubDomains`	الزام مرورگر به برقراری ارتباط انحصاری امن از طریق HTTPS به مدت ۱ سال و حفاظت در برابر حملات SSL Strip.
`Permissions-Policy`	`geolocation=(), microphone=(), camera=(), payment=()`	غیرفعال‌سازی سنسورها و سخت‌افزارهای حساس کلاینت توسط مرورگر جهت حفظ حریم خصوصی گزارش‌دهندگان.
`Cross-Origin Policies`	`COOP: same-origin / CORP: same-origin`	ایزولاسیون پردازش مرورگر و ممانعت از نشت حافظه متقابل از طریق کانال‌های جانبی مانند Spectre.
`Host Header Validation`	تطبیق پویا با `HERASAT_ALLOWED_HOSTS`	مسدودسازی حملات مسموم‌سازی هدر هاست (Host Header Injection) و DNS Rebinding.
`IP Whitelist` فایروال داخلی	ارزیابی با `HERASAT_ADMIN_ALLOWED_CIDRS`	تفکیک شبکه پنل ادمین و صدور خطای ۴۰۳ برای هر کلاینتی که خارج از رنج شبکه امن حراست باشد.

۱۸. مدل‌سازی جامع تهدیدات سامانه (Threat Model Matrix)

ماتریس تهدیدات سامانه منطبق بر متدولوژی STRIDE و نیازمندی‌های افتا:

شناسه	تهدید بالقوه (Threat)	سطح حمله (Attack Surface)	کنترل امنیتی موجود در کد	محل شواهد (Evidence)	ریسک باقیمانده
TH-01	تزریق کدهای SQL (SQLi)	کلیه فیلدهای فرم، جستجو، لاگین و ترکینگ	استفاده ۱۰۰٪ از پارامترهای پیوند داده شده ($1, $2) و نبود الحاق رشته در کوئری‌ها	admin_handlers.go:301-350 public_handlers.go:193-197	**ناچیز (Negligible)**
TH-02	تزریق اسکریپت متقابل (XSS)	متون گزارش، فیلد نام، چت و پیام‌های ارجاع	اعمال تابع escapeHTML در ۱۰۰٪ درج‌های DOM و تعریف هدر CSP با سیاست بدون اسکریپت درون‌خطی خارجی	admin.js:1280-1282 main.go:35	**بسیار پایین (Low)**
TH-03	جعل درخواست میان‌وبگاهی (CSRF)	تمامی اندپوینت‌های POST و تغییر وضعیت ادمین	الزام هدر سفارشی X-CSRF-Token، تطبیق زمان‌ثابت با کوکی و بررسی تطابق Origin با لیست سفید	csrf.go:24-48 CSRFMiddleware	**ناچیز (Negligible)**
TH-04	ترفیع دسترسی افقی (IDOR/BOLA)	شناسه گزارش‌ها در مشاهده، دانلود فایل و پاسخ	اعمال تابع canAdminAccessReport در هر درخواست و استعلام پیوند ارجاع گزارش برای مناطق	admin_handlers.go:83-98 forwarding_test.go:34	**ناچیز (Negligible)**
TH-05	حمله بروت‌فورس و حدس رمز	فرم ورود مدیران سامانه	محدودیت نرخ (0.08 req/s)، آزمون کپچا و قفل موقت ۱۵ دقیقه‌ای پس از ۵ تلاش ناموفق	security.go:649-807 main.go:158	**ناچیز (Negligible)**
TH-06	بارگذاری فایل‌های مخرب و وب‌شل	آپلود مدارک و مستندات گزارش	بررسی بایت جادویی هدر، پویش اسکریپت PDF، اسکن ClamAV، رمزنگاری بایت‌ها و خلع اجرای وب	public_handlers.go:247-325 metadata.go:83-147	**بسیار پایین (Low)**
TH-07	جعل آدرس آی‌پی (IP Spoofing)	هدرهای X-Forwarded-For و X-Real-IP	نادیده‌گرفتن مطلق هدرهای کلاینت مگر آنکه فرستنده بسته جزو CIDRهای معتمد تعریف‌شده باشد	admin_auth.go:261-292 getIP()	**ناچیز (Negligible)**
TH-08	حمله بازپخش کپچا و توکن سشن	ارسال مکرر فرم گزارش یا ریکوئست‌های تکراری	ثبت امضای کپچا در دیتابیس با TryRedeem و قفل ورود نشست‌های همزمان با broadcast بلادرنگ	captcha.go:67-111 security.go:86-140	**ناچیز (Negligible)**
TH-09	شنود اطلاعات در سرور یا نشت دیتابیس	دسترسی به فایل دیتابیس یا پشتیبان	رمزنگاری دو لایه‌ای کلیه فیلدهای متنی و باینری با AES-256-GCM؛ بدون کلید داده‌ها ناخوانا هستند	crypto.go:65-91 migration_v2.go:12-80	**بسیار پایین (Low)**
TH-10	حذف شواهد تخلف در دیتابیس	دستکاری لاگ‌ها توسط ادمین نفوذی	اعمال تریگرهای بلاک‌کننده WORM و شکسته‌شدن زنجیره هش SHA-256 و ارسال موازی به SIEM	schema.sql:145-165 admin_auth.go:322-350	**ناچیز (Negligible)**

۱۹. مهم‌ترین نقاط قوت امنیتی سامانه (Security Strengths)

کنترل‌های برجسته زیر با اتکا به شواهد صریح سورس‌کد و آزمون‌های موفق استخراج شده‌اند:

SEC-STR-01 — پیاده‌سازی بومی بدون اتکا به فریم‌ورک‌های سنگین و آسیب‌پذیر خارجی

هدف: کاهش اساسی سطح حمله (Attack Surface) و مصونیت در برابر زنجیره آسیب‌پذیری‌های شخص ثالث (Supply Chain Vulnerabilities).

نحوه پیاده‌سازی: کل هسته برنامه با بسته استاندارد `net/http` در زبان Go کامپایل شده و هیچ فریم‌ورک سنگین خارجی (مانند Gin یا Echo با ده‌ها پکیج وابسته) استفاده نشده است. فایل `go.mod` تنها به دو کتابخانه تمیز محدود است.

شواهد فنی: `main.go:85-264` / `go.mod:5-8`

سطح اطمینان: تأییدشده قطعی (سطح ۱)

SEC-STR-02 — رمزنگاری انتخابی و چندکلیدی فیلدها و فایل‌ها با AES-256-GCM

هدف: حفظ محرمانگی گزارش‌های فساد، مشخصات شاکیان و مدارک حتی در صورت مصالحه کامل سرور پایگاه داده.

نحوه پیاده‌سازی: بر خلاف سامانه‌های سنتی که متون را به صورت شفاف در SQL ذخیره می‌کنند، تمام فیلدهای شرح گزارش، نام، تلفن و مسیر فایل‌ها به صورت رشته‌های رمزگذاری شده احرازهویت‌شده (`v2:f:...` و `v2:p:...`) ذخیره می‌شوند. بایت‌های فایل‌ها نیز با هدر `HENC` کدگذاری می‌شوند.

شواهد فنی: `public_handlers.go:165-200` / `crypto.go:176-236` / `crypto.go:65-144`

سطح اطمینان: تأییدشده قطعی (سطح ۱)

SEC-STR-03 — سیستم جامع دفترکل ممیزی ضد دستکاری WORM و هش پیوسته Merkle Chain

هدف: تضمین انکارناپذیری (Non-Repudiation) و غیرقابل حذف بودن فعالیت‌های مدیران و بازرسان حراست.

نحوه پیاده‌سازی: هر لاگ وابسته به هش ردیف ماقبل خود است. تریگرهای اختصاصی موتور PostgreSQL هرگونه کوئری DELETE، UPDATE یا TRUNCATE روی جدول لاگ را با خطای امنیتی سقط می‌کنند. علاوه بر آن، ارسال لاگ‌ها به سیستم SIEM خارجی از طریق استاندارد RFC 5424 همزمان صورت می‌گیرد.

شواهد فنی: `schema.sql:145-165` / `admin_auth.go:294-350` / `syslog.go:48-96`

سطح اطمینان: تأییدشده قطعی (سطح ۱ و ۲)

SEC-STR-04 — اعتبارسنجی باینری، خنثی‌سازی فراداده هویتی و پویش کدهای فعال PDF

هدف: جلوگیری تام از نفوذ از طریق بارگذاری فایل، ممانعت از کشف هویت فرستنده از طریق متادیتای دوربین/GPS و مقابله با اکسپلویت‌های اجرایی اسناد اداری.

نحوه پیاده‌سازی: بایت‌های جادویی باینری بررسی شده، تصاویر برای امحای کامل EXIF بازکدگذاری می‌گردند، ساختار PDF برای دستورات `/JavaScript` اسکن و فایل‌ها بدون داشتن روت استاتیک با سطح دسترسی سخت‌گیرانه سیستمی روی سرور ذخیره می‌شوند.

شواهد فنی: `public_handlers.go:247-325` / `metadata.go:14-147`

سطح اطمینان: تأییدشده قطعی (سطح ۱)

SEC-STR-05 — ممانعت قطعی از ورود همزمان (Single Active Session Enforcement)

هدف: جلوگیری از اشتراک‌گذاری اکانت‌های سازمانی میان پرسنل و مسدودسازی سوءاستفاده‌های ناشی از سرقت توکن نشست.

نحوه پیاده‌سازی: ثبت سشن جدید فوراً سشن‌های قبلی همان کاربر را با علت `CONCURRENT_LOGIN` مسدود و از طریق SSE مرورگر قبلی را از سامانه بیرون می‌اندازد.

شواهد فنی: `admin_handlers.go:38-50` / `security.go:86-140`

سطح اطمینان: تأییدشده قطعی (سطح ۱)

SEC-STR-06 — تست‌پذیری و پوشش ۲۹ سناریوی آزمون امنیتی خودکار (Automated Security Test Suite)

هدف: اطمینان از عدم پسرفت امنیتی (Regression) حین توسعه آتی سامانه.

نحوه پیاده‌سازی: مخزن آزمون‌ها در پوشه `test/` شامل ۲۹ اسکریپت آزمایشی تخصصی است که رفتارهای قفل حساب، پایداری سشن در ری‌استارت، جعل IP، دستکاری بایت‌های رمزنگاری، دورزدن محدودیت طول ورودی و فیلترینگ کلمات را تحت سنجش قرار می‌دهند.

شواهد فنی: `test/*.go` (شامل ۲۹ فایل مجزا و کامپایل‌پذیر)

سطح اطمینان: تأییدشده قطعی (سطح ۴)

۲۰. یافته‌ها، آسیب‌پذیری‌های بالقوه و شکاف‌های ارزیابی (Security Findings)

بر اساس اصل صداقت علمی و شفافیت ارزیابی رسمی افتا، موارد زیر که نیازمند توجه، پیکربندی صحیح یا ارتقا پیش از بهره‌برداری نهایی هستند مستند می‌گردند:

FINDING-01: غیرفعال بودن پیش‌فرض اتصال آنتی‌ویروس ClamAV در فایل کانفیگ نمونه

شدت: متوسط (Medium)

محل شواهد: `.env.example:28` و `clamav.go:27`

شرح و اثر امنیتی: منطق اتصال به دیمون ClamAV با پروتکل INSTREAM به‌خوبی در کد پیاده‌سازی شده است؛ اما متغیر محیطی `HERASAT_CLAMAV_ENABLED` در نمونه کانفیگ مقدار `false` دارد. در صورتی که مدیر زیرساخت حین استقرار در ویندوز/لینوکس دیمون ClamAV را مستقر نکرده و این پرچم را فعال نسازد، پویش ضد بدافزار فعال نخواهد شد (اگرچه اعتبارسنجی بایت‌های جادویی و فیلتر اسکریپت PDF همچنان مانع فایل‌های خطرناک می‌شوند).

سناریوی سوءاستفاده: فرستادن یک فایل با باینری معتبر مجاز (مانند تصویر یا PDF فاقد جاوااسکریپت) اما حاوی اکسپلویت شناخته‌شده سیستمی برای هدف قرار دادن نرم‌افزارهای نمایشگر ایستگاه کاری بازرسان.

راهکار اصلاحی: دیمون ClamAV بر روی سرور مستقر و در فایل تولیدی `.env` مقدار `HERASAT_CLAMAV_ENABLED=true` به عنوان پیش‌نیاز راه‌اندازی الزامی گردد.

FINDING-02: غیرفعال بودن پیش‌فرض خروجی ریموت Syslog در کانفیگ نمونه

شدت: متوسط (Medium)

محل شواهد: `.env.example:33` و `syslog.go:49`

شرح و اثر امنیتی: کدهای شیپر Syslog (RFC 5424) کامل و عملیاتی هستند، اما به‌طور پیش‌فرض در `.env.example` متغیر `HERASAT_SYSLOG_ENABLED` برابر با `false` است. در صورت عدم تنظیم آدرس SIEM حراست، ثبت لاگ‌ها منحصراً در جدول دیتابیس محلی انجام می‌شود.

سناریوی سوءاستفاده: در صورت از کار افتادن کامل سخت‌افزار سرور دیتابیس یا بروز حوادث فیزیکی، استخراج سریع سوابق از مرکز SOC امکان‌پذیر نخواهد بود.

راهکار اصلاحی: پیش از افتتاح سامانه، آدرس لاگ‌سرور مرکزی سازمان در `HERASAT_SYSLOG_ADDR` درج و فعال‌سازی آن توسط تیم شبکه تست گردد.

FINDING-03: وجود فلگ‌های حالت توسعه (Dev Mode Fallback) در شروط اعتبارسنجی سشن

شدت: پایین (Low)

محل شواهد: `main.go:95` و `main.go:124`

شرح و اثر امنیتی: در سورس‌کد `main.go` شروطی مانند `HERASAT_DEV_MODE=1` یا `HERASAT_INSECURE_HTTP=true` برای راحتی تست محلی توسعه‌دهندگان تعبیه شده که اجازه می‌دهد بدون گواهی TLS برنامه استارت شود و کوکی‌های Secure را غیرفعال سازد.

سناریوی سوءاستفاده: اگر پرسنل نصب ناخواسته فایل `env.` محیط تست حاوی `HERASAT_DEV_MODE=1` را روی سرور عملیاتی کپی کنند، کوکی‌ها بدون پرچم Secure ارسال شده و در معرض شنود شبکه داخلی قرار می‌گیرند.

راهکار اصلاحی: در مستند استقرار قید شود که هیچ‌یک از متغیرهای `HERASAT_DEV_MODE` یا `HERASAT_INSECURE_HTTP` نباید در سرور پروداکشن وجود داشته باشند، و متغیر `HERASAT_COOKIE_SECURE=true` همواره الزامی باشد.

FINDING-04: وابستگی ابزار تبدیل Word به مفسر خارجی Python در سرور

شدت: پایین (Low)

محل شواهد: `admin_handlers.go:2970-3020`

شرح و اثر امنیتی: تابع خروجی سند Word از پرونده‌ها (`ExportReportDocxHandler`) اسکریپت پایتون `scripts/generate_docx.py` را از طریق زیرپردازه سیستم‌عامل با ورودی‌های JSON از طریق استاندارد اینپوت فراخوانی می‌کند. آرگومان‌های خط فرمان به صورت کامپوننت امن با `exec.CommandContext` ارسال شده و از Command Injection مصون است؛ اما نیاز به مفسر پایتون روی سرور دارد.

سناریوی سوءاستفاده: در صورت عدم دسترسی امن به مفسر پایتون یا تغییر سطح دسترسی فایل‌های اسکریپت، امکان صدور خطای ۵۰۰ در این بخش وجود دارد.

راهکار اصلاحی: مجوز فایل‌های پوشه `scripts/` روی سرور به‌صورت Read-Only تنظیم و دسترسی نوشتن برای کاربر اجرای برنامه سلب شود.

FINDING-05: عدم وجود مکانیزم چرخش خودکار کلید مستر (Key Rotation Automation)

شدت: پایین (Low)

محل شواهد: `crypto.go:42-55` و `migration_v2.go:12-80`

شرح و اثر امنیتی: سامانه قابلیت بازرمزنگاری داده‌های قدیمی را دارد (`reencryptLegacyData`)، اما در صورت تصمیم به چرخش دوره‌ای کلید اصلی ۳۲ بایتی AES، فرآیند باید به صورت دستی یا از طریق اسکریپت مایگریشن اختصاصی انجام پذیرد و کلید در متغیر محیطی تعویض گردد.

راهکار اصلاحی: تهیه دستورالعمل اجرایی مدون برای چرخش سالانه کلید اصلی و تهیه پشتیبان پیش از اعمال مایگریشن.

۲۱. ماتریس جامع تطبیق با الزامات مرکز مدیریت راهبردی افتا (AFTA Compliance Matrix)

سرفصل الزامات امنیتی افتا	مفاد الزام / ضابطه حاکمیتی	وضعیت در سامانه	شواهد فنی در سورس‌کد (Evidence)	توضیحات و شکاف
رمزنگاری داده‌های حساس	رمزنگاری قوی داده‌های محرمانه در حالت استراحت با الگوریتم‌های استاندارد تصویب‌شده.	**Implemented**	`crypto.go:65-91` `AES-256-GCM / HKDF`	تمامی فیلدهای شرح، نام، تلفن و ضمائم کاملاً رمزشده ذخیره می‌شوند.
نگهداری امن کلمات عبور	ممنوعیت ذخیره رمز به‌صورت متن واضح یا MD5/SHA1؛ استفاده از توابع دارای هزینه محاسباتی و نمک تصادفی.	**Implemented**	`crypto.go:245-258` `Argon2id 64MB / t=3`	منطبق بر مدرن‌ترین استاندارد PHC همراه با بازهشینگ خودکار.
احراز هویت چندعاملی (MFA)	الزام احراز هویت دومرحله‌ای مبتنی بر زمان برای دسترسی‌های مدیریتی سامانه‌های حساس دولتی.	**Implemented**	`mfa.go:84-140` `RFC 6238 TOTP`	قابلیت فعال‌سازی 2FA در پنل کاربری مدیران با QR-Code و کلید Base32.
مقابله با حملات تزریق SQL	عدم استفاده از کوئری‌های پویا و الزام به پرس‌وجوهای پارامتریک در کلیه ارتباطات با پایگاه داده.	**Implemented**	`admin_handlers.go` `db.go / schema.sql`	۱۰۰٪ کوئری‌ها پارامتریک با مقادیر $1, $2,... هستند.
مقابله با حملات CSRF	اعتبارسنجی منشأ درخواست‌ها و استفاده از توکن‌های غیرقابل‌پیش‌بینی برای متدهای تغییردهنده داده.	**Implemented**	`csrf.go:24-48` `CSRFMiddleware`	بررسی هدر X-CSRF-Token به روش زمان‌ثابت و کوکی SameSite=Strict.
مصونیت لاگ‌ها از دستکاری	الزام پایداری لاگ‌های امنیتی به‌صورت WORM و عدم امکان تغییر یا حذف آن توسط کاربران سامانه.	**Implemented**	`schema.sql:145-165` `Triggers plpgsql`	مسدودسازی تریگری UPDATE و DELETE و ایجاد زنجیره هش Merkle.
ارسال رویدادها به SIEM	قابلیت ارسال متمرکز و بلادرنگ رویدادهای رخداده به سامانه‌های مانیتورینگ امنیتی دستگاه اجرایی.	**Implemented**	`syslog.go:33-96` `SyslogShipper (RFC 5424)`	آماده اتصال به سرور SOC؛ نیازمند درج آدرس سرور در محیط عملیاتی است.

تفکیک نقش‌ها و حوزه‌ها	اعمال اصل حداقل دسترسی و جلوگیری از ترفیع افقی/عمودی کارشناسان ستاد و مناطق.	**Implemented**	admin_handlers.go:83-98 canAdminAccessReport	مسئولین مناطق منحصراً پرونده‌های ارجاعی را می‌بینند.
امنیت فایل‌های پیوست	اعتبارسنجی نوع واقعی فایل باینری، امحای فراداده، ممانعت از وب‌شل و اسکن ویروس.	**Implemented**	metadata.go:83-147 clamav.go:50-95	اعتبارسنجی امضای باینری، پالایش PDF، حذف EXIF و مانیتور ClamAV.
محدودسازی دسترسی شبکه	محدود کردن دسترسی به پنل ادمین بر اساس آدرس‌های IP و رنج‌های شبکه مجاز سازمان.	**Implemented**	middleware.go:38-62 AdminIPWhitelistMiddleware	قابلیت سد فایروالی بر اساس CIDRهای مجاز در کد فعال است.
پیکربندی امن وب‌سرور و TLS	اجباری بودن پروتکل امن TLS 1.2 به بالا و استفاده انحصاری از Cipher Suiteهای دارای PFS.	**Implemented**	main.go:245-257 tls.Config TLS 1.2+	محدود به ECDHE و GCM/ChaCha20. در استقرار با Caddy یا مستقیم تأیید شده.
پشتیبان‌گیری رمزنگاری‌شده	سازوکار منظم پشتیبان‌گیری روزانه و آفلاین از پایگاه داده و فایل‌ها.	**Deployment Verification**	دستورالعمل استقرار	نیازمند پیکربندی اسکریپت پشتیبان‌گیری دوره‌ای در سطح سیستم‌عامل سرور.

۲۲. چک‌لیست راستی‌آزمایی محیط استقرار (Deployment Verification Checklist)

تیم امنیت زیرساخت اداره کل آموزش و پرورش موظف است پیش از بارگذاری نهایی سامانه دیده‌بان امین در شبکه اینترنت، گواهی راستی‌آزمایی زیر را تکمیل نماید:

ردیف	آیتم کنترلی در سطح زیرساخت سرور	معیار پذیرش امنیتی	وضعیت پیشنهادی	مسئول اقدام
۱	تولید کلید مستر AES-256 رمزنگاری	تولید رشته دقیقاً ۳۲ بایتی با انتروپی بالا در HERASAT_AES_KEY	الزامی (Mandatory)	مدیر امنیت سامانه
۲	فعال‌سازی پرچم کوکی امن	تنظیم HERASAT_COOKIE_SECURE=true در فایل .env	الزامی (Mandatory)	مدیر سرور
۳	محدودسازی رنج شبکه ادمین	درج ساب‌نت شبکه داخلی حراست در HERASAT_ADMIN_ALLOWED_CIDRS	الزامی (Mandatory)	مدیر شبکه
۴	پیکربندی پروکسی‌های مورد اعتماد	درج IP رورس‌پروکسی در HERASAT_TRUSTED_PROXIES جهت صحت گزارش IP واقعی	الزامی (Mandatory)	مدیر وب‌سرور
۵	فعال‌سازی دیمون آنتی‌ویروس ClamAV	اجرای دیمون و ست‌کردن HERASAT_CLAMAV_ENABLED=true	توصیه اکید	پشتیبان لینوکس/ویندوز
۶	اتصال به سرور گزارش‌گیری SIEM/Syslog	ست‌کردن HERASAT_SYSLOG_ENABLED=true و آدرس لاگ‌سرور حراست	توصیه اکید	کارشناس SOC
۷	تنظیم دامنه در Host Header و CORS	تنظیم FQDN دقیق سامانه در HERASAT_ALLOWED_HOSTS و HERASAT_ALLOWED_ORIGINS	الزامی (Mandatory)	مدیر وب‌سرور
۸	سطح دسترسی فایل‌های اجرایی و آپلود	مجوز 0700 برای پوشه secure_uploads و سلب دسترسی وب دایرکت	الزامی (Mandatory)	مدیر سیستم‌عامل
۹	برنامه پشتیبان‌گیری منظم دیتابیس	اجرای اسکریپت روزانه pg_dump با ذخیره‌سازی آفلاین و رمزنگاری پشتیبان	الزامی (Mandatory)	ادمین پایگاه داده
۱۰	حذف کامل فایل‌های توسعه و دیباگ	اطمینان از نبود متغیر HERASAT_DEV_MODE در متغیرهای سیستم‌عامل	الزامی (Mandatory)	تیم ممیزی نهایی

۲۳. فهرست نمایه شواهد فنی و قطعی سورس‌کد (Evidence Index)

شناسه	عنوان کنترل امنیتی	نوع شواهد (Evidence Type)	محل دقیق در سورس‌کد	توضیح فنی مختصر
SEC-001	رمزنگاری AES-256-GCM	سورس‌کد Go بومی	`crypto.go:65-91`	تولید تصادفی Nonce، مهر احراز اصالت داده
SEC-002	اشتقاق کلید با HKDF	سورس‌کد Go بومی	`crypto.go:29-55`	تفکیک کلید فیلدها، فایل‌ها و امضای کپچا
SEC-003	هشینگ کلمات عبور با Argon2id	سورس‌کد Go	`crypto.go:245-258`	زمان ۳، حافظه ۶۴ مگابایت، ۴ ترد، نمک ۱۶ بایت
SEC-004	احراز هویت دو عاملی TOTP	سورس‌کد Go بومی	`mfa.go:84-140`	RFC 6238، ممانعت از Replay در پنجره ۳۰ ثانیه
SEC-005	قفل موقت Brute-force	سورس‌کد Go + دیتابیس	`security.go:649-807`	محرومیت ۱۵ دقیقه‌ای پس از ۵ شکست متوالی
SEC-006	ابطال ورود همزمان (Single Session)	سورس‌کد Go + جدول سشن	`security.go:86-140`	اخراج نشست قبلی و اطلاع‌رسانی زنده با SSE
SEC-007	تفکیک مناطق و ممانعت از IDOR	سورس‌کد Go	`admin_handlers.go:83-98`	استعلام پیوند ارجاع پرونده در canAdminAccessReport
SEC-008	دفترکل WORM تغییرناپذیر	اسکریپت SQL + تریگر پلاس	`schema.sql:145-165`	مسدودسازی Update و Delete روی audit_logs
SEC-009	زنجیره هش رمزنگاری ممیزی	سورس‌کد Go	`admin_auth.go:294-350`	محاسبه پیوسته entry_hash با استفاده از prev_hash
SEC-010	ارسال رویدادها به SIEM (Syslog)	سورس‌کد Go	`syslog.go:33-96`	ارسال رویدادهای حفاظتی منطبق بر RFC 5424
SEC-011	اعتبارسنجی باینری Magic Bytes	سورس‌کد Go	`metadata.go:83-147`	بررسی هدر بایت‌های PDF، تصویر و آرشیو
SEC-012	اسکن اسکریپت‌های فعال در PDF	سورس‌کد Go	`metadata.go:59-81`	کشف و مسدودسازی /Launch، JavaScript و /JS
SEC-013	پاکسازی متادیتا و EXIF تصاویر	سورس‌کد Go بومی	`metadata.go:14-43`	دیکود و بازانکود پیکسل‌ها برای امحای متادیتا
SEC-014	اسکن آنتی‌ویروس ClamAV	سورس‌کد Go	`clamav.go:50-95`	پروتکل INSTREAM جریانی به دیمون محلی

SEC-015	محدودساز نرخ توکن باکت	سورس‌کد Go بومی	`security.go:535-630`	محدودیت مستقل برای لاگین، سابمیت و کپچا
SEC-016	جلوگیری از بازپخش کپچا (Replay)	سورس‌کد Go + دیتابیس	`captcha.go:67-111`	ثبت امضا در used_captcha_tokens با TryRedeem
SEC-017	فیلتر لیست سفید IP ادمین	میان‌افزار Go	`middleware.go:38-62`	بررسی رنج شبکه کلاینت با CIDRهای مجاز
SEC-018	محافظت برابر جعل IP کلاینت	سورس‌کد Go	`admin_auth.go:261-292`	پالایش X-Forwarded-For بر اساس پروکسی معتمد
SEC-019	مجموعه هدرهای دفاع‌درعمق (CSP)	میان‌افزار Go	`main.go:35-46`	CSP سخت‌گیرانه، DENY فریم، nosniff و HSTS
SEC-020	اعتبارسنجی توکن ضدجعل CSRF	میان‌افزار Go بومی	`csrf.go:24-48`	بررسی هدر X-CSRF-Token به روش ConstantTime
SEC-021	پالایش متون غیراخلاقی (Profanity)	سورس‌کد Go	`profanity.go:12-360`	رجکس چندزبانه و ثبت تلاش در لاگ بازرسی
SEC-022	تست‌های خودکار خودآزمایی امنیتی	مجموعه تست Go	`test/*.go`	۲۹ سناریوی آزمون امنیتی واحد و یکپارچگی

۲۴. جمع‌بندی فنی و گواهی ممیزی امنیتی (Auditor Attestation)

این ممیزی جامع امنیتی نشان داد که سامانه «دیده‌بان امین» (ستاد خبری اداره کل آموزش و پرورش استان همدان) با برخورداری از معماری بومی در زبان Go، پایگاه داده ساختاریافته PostgreSQL، لایه رمزنگاری یکپارچه AES-256-GCM، سیستم ممیزی تغییرناپذیر WORM همراه با زنجیره هش رمزنگاری، خط لوله چندمرحله‌ای پالایش فایل، و مکانیزم‌های سخت‌گیرانه احراز هویت دوعاملی و ممانعت از ورود همزمان، دارای بلوغ امنیتی سطح بالا در تراز سامانه‌های حساس دولتی است.

تمامی ادعاهای امنیتی مندرج در این سند به خطوط معین سورس‌کد و آزمون‌های موفق اتوماتیک متصل بوده و سامانه فاقد هرگونه آسیب‌پذیری بحرانی (Critical) از قبیل تزریق SQL، دورزدن احراز هویت، ترفیع افقی دسترسی (IDOR) یا اجرای کدهای ناخواسته از طریق آپلود است.

گواهی تیم ارزیابی امنیتی جهت ارائه به افتا:
سامانه دیده‌بان امین از حیث معماری نرم‌افزار، توسعه امن کد و تدابیر دفاع‌درعمق، حائز شرایط فنی لازم جهت اخذ تأییدیه امنیتی از مرکز مدیریت راهبردی افتا تشخیص داده می‌شود؛ مشروط بر آنکه تیم فنی زیرساخت پیش از بهره‌برداری نهایی، مفاد ۱۰گانه مندرج در «چک‌لیست راستی‌آزمایی محیط استقرار» (بخش ۲۲) به‌ویژه فعال‌سازی ClamAV، اتصال SIEM و قفل هدرهای هاست و پروکسی را به طور کامل در بستر عملیاتی سرور پیاده‌سازی و نهایی نماید.

کارشناس ارشد ممیزی امنیت نرم‌افزار و معماری سایبری

[محل امضا و تأیید فنی ممیز مستقل]

اداره حراست و امنیت فناوری اطلاعات آموزش و پرورش استان همدان

[محل مهر و امضای ریاست حراست اداره کل]